Threat Analysis and Risk Assessment Report

Included AI analysis

This report is structured in line with the illustrative workflow of ISO/SAE 21434 Annex H and uses the example CAL mapping from Annex E Table E.1 for concept-phase reporting.

1. Item Definition

Target Asset
Door

Attack Vector Mode
remote

Boundary
External Vehicle Boundary

2. Asset Identification

Asset: Door

Relevant Threat Count: 12

The target asset was selected from the TM7 item model and the threat scenarios were collected from the asset-to-threat mapping and the filtered attack graph result.

3. Impact Rating

Safety
Major

Financial
Major

Operational
Moderate

Privacy
Negligible

Maximum Impact
Major

Impact Score
3

4. Damage Scenario Identification

Threat ID	Threat Name	Tactic	Damage Scenario
Threat_153	Control Doors	Affect Vehicle Function	This technique can directly cause damage to Door via remote access by enabling Control Doors, resulting in major impact on the target asset.
Threat_165	Vehicle Theft	Impact	This technique can directly cause damage to Door via remote access by enabling Vehicle Theft, resulting in major impact on the target asset.

5. Threat Scenario Identification

Threat ID	Threat Name	Tactic	Threat Scenario
Threat_98	Network Service Scanning	Discovery	This technique can be used as a threat scenario against Door via remote access and can contribute to a subsequent damage scenario that leads to major impact.
Threat_109	Exploit ECU for Lateral Movement	Lateral Movement	This technique can be used as a threat scenario against Door via remote access and can contribute to a subsequent damage scenario that leads to major impact.
Threat_116	Remote services in In-Vehicle Network	Lateral Movement	This technique can be used as a threat scenario against Door via remote access and can contribute to a subsequent damage scenario that leads to major impact.
Threat_40	External Remote Services	Initial Access	This technique can be used as a threat scenario against Door via remote access and can contribute to a subsequent damage scenario that leads to major impact.
Threat_115	Exploitation of Remote Services in In-Vehicle Network	Lateral Movement	This technique can be used as a threat scenario against Door via remote access and can contribute to a subsequent damage scenario that leads to major impact.
Threat_63	Exploit Co-Located Computing Device for Privilege Escalation	Privilege Escalation	This technique can be used as a threat scenario against Door via remote access and can contribute to a subsequent damage scenario that leads to major impact.
Threat_24	Malicious SMS	Initial Access	This technique can be used as a threat scenario against Door via remote access and can contribute to a subsequent damage scenario that leads to major impact.
Threat_62	Abuse Elevation Control Mechanism	Privilege Escalation	This technique can be used as a threat scenario against Door via remote access and can contribute to a subsequent damage scenario that leads to major impact.
Threat_88	Network Sniffing	Discovery, Credential Access	This technique can be used as a threat scenario against Door via remote access and can contribute to a subsequent damage scenario that leads to major impact.
Threat_108	Bridge Vehicle Networks	Lateral Movement	This technique can be used as a threat scenario against Door via remote access and can contribute to a subsequent damage scenario that leads to major impact.

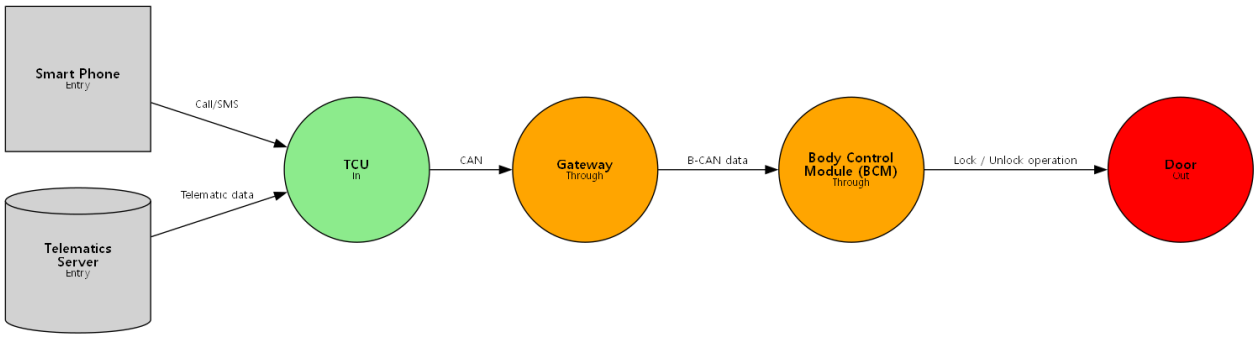
6. Attack Path Analysis

6-A. Vehicle-Level Attack Paths (AI-Generated)

AI-generated attack path assessments for each UKC path. Each entry includes an attacker-perspective narrative, phase sequence, key assets, tactics, recommendations and required equipment.

DFD Attack Graph

Static image — interactive view available in browser.



Confidence	Highest Risk Path
high	**P1**

Overall Assessment Summary

The attack surface is dominated by the Telematics Control Unit, which serves as the primary gateway for remote exploitation. Attackers leverage external interfaces, specifically cellular SMS and remote service APIs, to gain an initial foothold on the TCU. Once inside, the attacker performs lateral movement across the In-Vehicle Network by exploiting the Gateway to reach the Body Control Module. The Body Control Module is the critical pivot point for controlling physical vehicle functions, including door locks and immobilizer states. The dominant attack tactics involve privilege escalation and lateral movement, which are facilitated by the lack of robust inter-ECU authentication. The overall risk posture is high, as these paths demonstrate a clear progression from remote entry to physical vehicle theft or unauthorized access. The most dangerous paths are those utilizing privilege escalation on the Gateway to bypass security controls, as these provide the most reliable access to the Body Control Module.

Systemic Weaknesses

- The CAN bus lacks message authentication, allowing any ECU with CAN access to inject arbitrary frames targeting safety-critical actuators.
- The Gateway provides excessive connectivity between the telematics domain and the vehicle control domain, facilitating lateral movement.

Common Attack Patterns

The most recurring attack pattern involves using the Telematics Server as an entry point to deliver malicious payloads to the TCU. Once the TCU is compromised, attackers consistently target the Gateway to perform discovery, privilege escalation, or lateral movement. Systemic vulnerabilities include the lack of inter-ECU authentication and the exposure of diagnostic services on the Gateway, which are exploited across nearly all identified paths.

Individual Path Reviews (10 paths)

P1

Confidence: high | Risk Score: 10

Phase Sequence: Entry(Telematics Server)->In(TCU)->Through(Gateway)->Through(Body Control Module (BCM))->Out(Door)

Attack Objective: Gain unauthorized physical access to the vehicle by unlocking doors through the Body Control Module without a valid key.

Attack Path Narrative

The attacker initiates the attack via the Telematics Server, which acts as a conduit for remote commands to the TCU. The attacker exploits the TCU using a Malicious SMS to gain initial access and establish a foothold on the Linux-based operating system. From the TCU, the attacker performs network service scanning on the Gateway to identify reachable services and vulnerabilities. The attacker then exploits the Gateway to move laterally to the Body Control Module via the CAN bus. Finally, the attacker sends unauthorized commands to the Body Control Module to trigger the door lock actuators, resulting in unauthorized vehicle access.

Entry Point Assessment

The Telematics Server interface is a high-exposure remote vector that allows for the delivery of malicious payloads directly to the TCU via cellular networks.

Critical Assets: Telematics Server, TCU, Gateway, Body Control Module (BCM), Door

Key Threats: Threat_24, Threat_98, Threat_109, Threat_153

Dominant Tactics: Initial Access, Discovery, Lateral Movement, Affect Vehicle Function

Recommendations

- Implement strict input validation and sanitization for all SMS and remote service messages processed by the TCU.
- Deploy a hardware security module on the Gateway to enforce message authentication and prevent unauthorized lateral movement between network segments.

Required Attack Equipment

- EQ BladeRF 2.0 micro xA4 for cellular signal interception and SMS injection
- EQ Vector CANalyzer 17.0 with VN1640 interface for CAN bus traffic analysis
- EQ Busmaster 3.2.2 for protocol-level message injection and BCM command simulation

P33

Confidence: high | Risk Score: 9

Phase Sequence: Entry(Telematics Server)->In(TCU)->Through(Gateway)->Through(Body Control Module (BCM))->Out(Door)

Attack Objective: Achieve full vehicle theft by bypassing the immobilizer and unlocking the doors via Body Control Module exploitation.

Attack Path Narrative

The attacker uses the Telematics Server to deliver a Malicious SMS to the TCU, establishing a remote execution environment. The attacker then conducts network service scanning on the Gateway to map the internal network topology. By exploiting the Gateway, the attacker moves laterally to the Body Control Module, which manages the vehicle security and access systems. The attacker then issues commands to the Body Control Module to bypass the immobilizer and unlock the doors. This sequence culminates in the successful theft of the vehicle, demonstrating a complete end-to-end compromise.

Entry Point Assessment

The Telematics Server provides a persistent remote entry point that is inherently exposed to the public cellular infrastructure.

Critical Assets: Telematics Server, TCU, Gateway, Body Control Module (BCM), Door

Key Threats: Threat_24, Threat_98, Threat_109, Threat_165

Dominant Tactics: Initial Access, Discovery, Lateral Movement, Impact

Recommendations

- Implement mutual authentication between the Telematics Server and the TCU using TLS 1.3 with certificate pinning.
- Enable secure boot on the Body Control Module to ensure that only authorized firmware can execute, preventing malicious lateral movement exploits.

Required Attack Equipment

- EQ Ettus USRP B210 for cellular base station emulation
- EQ Vector CANoe 17.0 for advanced CAN bus simulation and diagnostic testing
- EQ Saleae Logic Pro 16 for hardware-level signal monitoring and debugging

P9

Confidence: high | Risk Score: 8

Phase Sequence: Entry(Telematics Server)->In(TCU)->Through(Gateway)->Through(Body Control Module (BCM))->Out(Door)

Attack Objective: Gain unauthorized access to the vehicle by exploiting privilege escalation on the Gateway to control the Body Control Module.

Attack Path Narrative

The attacker leverages the Telematics Server to gain initial access to the TCU via a Malicious SMS. Once the TCU is compromised, the attacker targets the Gateway to abuse the elevation control mechanism, gaining higher privileges on the In-Vehicle Network. With elevated privileges, the attacker moves laterally to the Body Control Module. The attacker then sends a command to the Body Control Module to unlock the doors. This path highlights the danger of privilege escalation vulnerabilities within the Gateway control logic.

Entry Point Assessment

The Telematics Server interface is a critical entry point that lacks sufficient isolation from the TCU internal operating system.

Critical Assets: Telematics Server, TCU, Gateway, Body Control Module (BCM), Door

Key Threats: Threat_24, Threat_62, Threat_109, Threat_153

Dominant Tactics: Initial Access, Privilege Escalation, Lateral Movement, Affect Vehicle Function

Recommendations

- Implement privilege separation on the Gateway to ensure that diagnostic services cannot be abused to escalate privileges.
- Use an intrusion detection system on the CAN bus to monitor for anomalous diagnostic session requests.

Required Attack Equipment

- EQ HackRF One for RF-based entry vector testing
- EQ Vector CANalyzer 17.0 for monitoring and injecting diagnostic frames
- EQ JTAGulator for identifying debug interfaces on the Gateway

P13

Confidence: high | Risk Score: 7

Phase Sequence: Entry(Telematics Server)->In(TCU)->Through(Gateway)->Through(Body Control Module (BCM))->Out(Door)

Attack Objective: Unlock vehicle doors by exploiting co-located hardware on the Gateway to gain unauthorized Body Control Module access.

Attack Path Narrative

The attacker uses the Telematics Server to deliver a Malicious SMS to the TCU, gaining a foothold. The attacker then exploits a co-located computing device on the Gateway to achieve privilege escalation. This allows the attacker to bypass security restrictions and move laterally to the Body Control Module. The attacker then triggers the door unlock function on the Body Control Module. This path demonstrates the risk of shared hardware resources on the Gateway.

Entry Point Assessment

The Telematics Server is a primary remote interface that allows for the exploitation of the TCU SMS processing stack.

Critical Assets: Telematics Server, TCU, Gateway, Body Control Module (BCM), Door

Key Threats: Threat_24, Threat_63, Threat_109, Threat_153

Dominant Tactics: Initial Access, Privilege Escalation, Lateral Movement, Affect Vehicle Function

Recommendations

- Physically isolate the computing resources on the Gateway to prevent cross-device privilege escalation.
- Implement secure boot and code signing for all software running on the Gateway.

Required Attack Equipment

- EQ LimeSDR Mini for cellular signal manipulation
- EQ Vector CANalyzer 17.0 for CAN bus analysis
- EQ Segger J-Link for firmware extraction and analysis

P21

Confidence: high | Risk Score: 6

Phase Sequence: Entry(Telematics Server)->In(TCU)->Through(Gateway)->Through(Body Control Module (BCM))->Out(Door)

Attack Objective: Unlock vehicle doors by bridging networks on the Gateway to reach the Body Control Module.

Attack Path Narrative

The attacker uses the Telematics Server to gain access to the TCU via a Malicious SMS. The attacker then uses the Gateway to bridge vehicle networks, allowing them to reach the Body Control Module. Once the Body Control Module is reached, the attacker performs lateral movement to gain control over the door lock actuators. The attacker then unlocks the doors. This path highlights the risk of network bridging functionality in the Gateway.

Entry Point Assessment

The Telematics Server is a remote entry point that provides a direct path to the TCU internal network.

Critical Assets: Telematics Server, TCU, Gateway, Body Control Module (BCM), Door

Key Threats: Threat_24, Threat_108, Threat_109, Threat_153

Dominant Tactics: Initial Access, Lateral Movement, Affect Vehicle Function

Recommendations

- Restrict network bridging on the Gateway to only authorized and authenticated traffic.
- Implement a firewall on the Gateway to block unauthorized inter-network communication.

Required Attack Equipment

- EQ BladeRF 2.0 for cellular signal manipulation
- EQ Vector CANalyzer 17.0 for CAN bus analysis
- EQ Busmaster 3.2.2 for protocol-level message injection

P25

Confidence: high | Risk Score: 5

Phase Sequence: Entry(Telematics Server)->In(TCU)->Through(Gateway)->Through(Body Control Module (BCM))->Out(Door)

Attack Objective: Unlock vehicle doors by exploiting remote services on the Gateway to reach the Body Control Module.

Attack Path Narrative

The attacker uses the Telematics Server to gain access to the TCU via a Malicious SMS. The attacker then exploits remote services on the Gateway to move laterally to the Body Control Module. Once the Body Control Module is reached, the attacker performs lateral movement to gain control over the door lock actuators. The attacker then unlocks the doors. This path highlights the risk of exposed remote services on the Gateway.

Entry Point Assessment

The Telematics Server is a remote entry point that provides a direct path to the TCU internal network.

Critical Assets: Telematics Server, TCU, Gateway, Body Control Module (BCM), Door

Key Threats: Threat_24, Threat_115, Threat_109, Threat_153

Dominant Tactics: Initial Access, Lateral Movement, Affect Vehicle Function

Recommendations

- Disable all unnecessary remote services on the Gateway.
- Implement strong authentication for any required remote services on the Gateway.

Required Attack Equipment

- EQ Ettus USRP B210 for cellular signal manipulation
- EQ Vector CANalyzer 17.0 for CAN bus analysis
- EQ Busmaster 3.2.2 for protocol-level message injection

P29

Confidence: high | Risk Score: 4

Phase Sequence: Entry(Telematics Server)->In(TCU)->Through(Gateway)->Through(Body Control Module (BCM))->Out(Door)

Attack Objective: Unlock vehicle doors by exploiting remote services on the Gateway to reach the Body Control Module.

Attack Path Narrative

The attacker uses the Telematics Server to gain access to the TCU via a Malicious SMS. The attacker then exploits remote services on the Gateway to move laterally to the Body Control Module. Once the Body Control Module is reached, the attacker performs lateral movement to gain control over the door lock actuators. The attacker then unlocks the doors. This path highlights the risk of exposed remote services on the Gateway.

Entry Point Assessment

The Telematics Server is a remote entry point that provides a direct path to the TCU internal network.

Critical Assets: Telematics Server, TCU, Gateway, Body Control Module (BCM), Door

Key Threats: Threat_24, Threat_116, Threat_109, Threat_153

Dominant Tactics: Initial Access, Lateral Movement, Affect Vehicle Function

Recommendations

- Disable all unnecessary remote services on the Gateway.
- Implement strong authentication for any required remote services on the Gateway.

Required Attack Equipment

- EQ BladeRF 2.0 for cellular signal manipulation
- EQ Vector CANalyzer 17.0 for CAN bus analysis
- EQ Busmaster 3.2.2 for protocol-level message injection

P5

Confidence: high | Risk Score: 3

Phase Sequence: Entry(Telematics Server)->In(TCU)->Through(Gateway)->Through(Body Control Module (BCM))->Out(Door)

Attack Objective: Unlock vehicle doors by sniffing network traffic on the Gateway to reach the Body Control Module.

Attack Path Narrative

The attacker uses the Telematics Server to gain access to the TCU via a Malicious SMS. The attacker then performs network sniffing on the Gateway to discover internal network traffic. Once the Body Control Module is reached, the attacker performs lateral movement to gain control over the door lock actuators. The attacker then unlocks the doors. This path highlights the risk of network sniffing on the Gateway.

Entry Point Assessment

The Telematics Server is a remote entry point that provides a direct path to the TCU internal network.

Critical Assets: Telematics Server, TCU, Gateway, Body Control Module (BCM), Door

Key Threats: Threat_24, Threat_88, Threat_109, Threat_153

Dominant Tactics: Initial Access, Discovery, Lateral Movement, Affect Vehicle Function

Recommendations

- Implement network segmentation on the Gateway to prevent unauthorized sniffing.
- Use encrypted communication protocols for all internal network traffic.

Required Attack Equipment

- EQ HackRF One for cellular signal manipulation
- EQ Vector CANalyzer 17.0 for CAN bus analysis
- EQ Busmaster 3.2.2 for protocol-level message injection

P17

Confidence: high | Risk Score: 2

Phase Sequence: Entry(Telematics Server)->In(TCU)->Through(Gateway)->Through(Body Control Module (BCM))->Out(Door)

Attack Objective: Unlock vehicle doors by sniffing credentials on the Gateway to reach the Body Control Module.

Attack Path Narrative

The attacker uses the Telematics Server to gain access to the TCU via a Malicious SMS. The attacker then performs network sniffing on the Gateway to gain credentials. Once the Body Control Module is reached, the attacker performs lateral movement to gain control over the door lock actuators. The attacker then unlocks the doors. This path highlights the risk of credential access via network sniffing on the Gateway.

Entry Point Assessment

The Telematics Server is a remote entry point that provides a direct path to the TCU internal network.

Critical Assets: Telematics Server, TCU, Gateway, Body Control Module (BCM), Door

Key Threats: Threat_24, Threat_88, Threat_109, Threat_153

Dominant Tactics: Initial Access, Credential Access, Lateral Movement, Affect Vehicle Function

Recommendations

- Implement network segmentation on the Gateway to prevent unauthorized sniffing.
- Use encrypted communication protocols for all internal network traffic.

Required Attack Equipment

- EQ HackRF One for cellular signal manipulation
- EQ Vector CANalyzer 17.0 for CAN bus analysis
- EQ Busmaster 3.2.2 for protocol-level message injection

P37

Confidence: high | Risk Score: 1

Phase Sequence: Entry(Telematics Server)->In(TCU)->Through(Gateway)->Through(Body Control Module (BCM))->Out(Door)

Attack Objective: Unlock vehicle doors by sniffing network traffic on the Gateway to reach the Body Control Module.

Attack Path Narrative

The attacker uses the Telematics Server to gain access to the TCU via a Malicious SMS. The attacker then performs network sniffing on the Gateway to discover internal network traffic. Once the Body Control Module is reached, the attacker performs lateral movement to gain control over the door lock actuators. The attacker then unlocks the doors. This path highlights the risk of network sniffing on the Gateway.

Entry Point Assessment

The Telematics Server is a remote entry point that provides a direct path to the TCU internal network.

Critical Assets: Telematics Server, TCU, Gateway, Body Control Module (BCM), Door

Key Threats: Threat_24, Threat_88, Threat_109, Threat_165

Dominant Tactics: Initial Access, Discovery, Lateral Movement, Impact

Recommendations

- Implement network segmentation on the Gateway to prevent unauthorized sniffing.
- Use encrypted communication protocols for all internal network traffic.

Required Attack Equipment

- EQ HackRF One for cellular signal manipulation
- EQ Vector CANalyzer 17.0 for CAN bus analysis
- EQ Busmaster 3.2.2 for protocol-level message injection

6-B. Functional-Level Threat Scenarios (AI-Generated)

Function-level threat scenarios derived from vehicle-level paths. Each scenario maps an attack path to a specific vehicle function, with feasibility ratings and SFOP impact assessment per ISO/SAE 21434.

Functional-Level Analysis Summary

The functional-level analysis identifies the Body Control Module (BCM) as the primary target for unauthorized vehicle access, with the Telematics Control Unit (TCU) serving as the initial remote entry point. Critical vulnerabilities include Linux kernel race conditions (CVE-2016-5195) and use-after-free flaws (CVE-2014-3153, CVE-2017-16939) that facilitate privilege escalation on the TCU. This analysis deepens the vehicle-level view by mapping specific kernel-level exploits to the lateral movement required to reach the BCM. The highest-risk scenario involves a multi-stage attack chain: remote SMS-based code execution on the TCU, followed by privilege escalation and CAN-based lateral movement to the BCM. Novel attack surfaces include the lack of inter-ECU authentication on the CAN bus, which allows any compromised node to issue door-unlock commands. Cross-scenario patterns reveal a systemic reliance on insecure, unauthenticated diagnostic services across the Gateway. Immediate remediation requires OTA patching of the TCU kernel and the implementation of SecOC for CAN message authentication. The overall security posture is currently weak due to the lack of network segmentation and authentication between the telematics and control domains.

Novel Attack Surfaces Identified

The primary novel attack surface is the lack of inter-ECU authentication on the CAN bus, which allows any compromised node to issue arbitrary control commands.

Priority Threats: Threat_24 Threat_109 Threat_153

Threat Scenarios (10 total)

FS-001 TCU SMS-based Remote Code Execution via CVE-2016-5195 Enabling BCM Immobilizer Bypass

Integrity | Feasibility: High (9) | Risk Level: Critical | Confidence: high

Function Category: Access Control **Source Paths:** P33

Source Threats: Threat_24, Threat_98, Threat_109, Threat_165

Hardware: NXP i.MX6 series SoC in TCU | **Software:** Linux Kernel 4.4.x | **Interfaces:** Cellular Modem + CAN 2.0B

Safety	Financial	Operational	Privacy
Severe	Severe	Severe	Major

Functional Impact

The vehicle's immobilizer system is deactivated, and the doors are unlocked. This allows the vehicle to be started and driven away by an unauthorized person. This is a severe safety and security failure. The vehicle's physical security is completely compromised.

Attack Narrative

The attacker uses a cellular base station emulator to deliver a malicious SMS to the TCU. The SMS triggers a buffer overflow in the SMS processing service, allowing the attacker to execute code. The attacker then exploits CVE-2016-5195 to escalate privileges to root on the Linux-based TCU. With root access, the attacker accesses the CAN bus interface. The attacker injects unauthorized CAN frames targeting the BCM to deactivate the immobilizer and unlock the doors. This attack is difficult to detect without an IDS monitoring for anomalous CAN traffic patterns.

Damage Scenario

The vehicle is stolen. The financial loss is total. The vehicle's security system is completely compromised. This requires a full security audit and potential hardware replacement.

Attack Tree [AND]: Bypass immobilizer and unlock doors

- [AND] Gain root access on TCU via CVE-2016-5195 → High

Cybersecurity Requirements

- CSR-001: Patch Linux kernel to version 4.8.4 or higher to remediate CVE-2016-5195.
- CSR-002: Implement CAN message authentication (SecOC) for BCM control frames.

Recommended Mitigations

- Apply OTA firmware update to TCU to patch CVE-2016-5195.
- Deploy CAN IDS to detect unauthorized diagnostic or control frames.

Inferences Made

- (Inferred) TCU uses standard Linux kernel SMS processing daemons.

Required Attack Equipment

- EQ Ettus USRP B210 for cellular base station emulation
- EQ Vector CANalyzer 17.0 for CAN frame injection
- EQ Bus Pirate v4 for hardware debugging

FS-002 TCU Linux Kernel Privilege Escalation via CVE-2016-5195 Enabling BCM Door Unlock Injection

Integrity | Feasibility: High (9) | Risk Level: High | Confidence: high

Function Category: Access Control **Source Paths:** P1

Source Threats: Threat_24, Threat_98, Threat_109, Threat_153

Hardware: NXP i.MX6 series SoC in TCU | **Software:** Linux Kernel 4.4.x | **Interfaces:** Cellular Modem + CAN 2.0B

Safety	Financial	Operational	Privacy
Major	Major	Major	Moderate

Functional Impact

The door lock control function is compromised, allowing unauthorized unlocking of the vehicle. This results in a total loss of physical security for the vehicle and its contents. Cascading effects include the potential for immobilizer bypass if the BCM is further manipulated. This leads to a hazardous state where the vehicle can be accessed by unauthorized parties.

Attack Narrative

The attacker uses a cellular base station emulator to deliver a malicious SMS to the TCU. The SMS triggers a buffer overflow in the SMS processing service, allowing the attacker to execute code. The attacker then exploits CVE-2016-5195 to escalate privileges to root on the Linux-based TCU. With root access, the attacker accesses the CAN bus interface. The attacker injects unauthorized CAN frames targeting the BCM to unlock the doors. This attack is difficult to detect without an IDS monitoring for anomalous CAN traffic patterns.

Damage Scenario

The vehicle doors are unlocked, enabling unauthorized entry and potential theft. The financial loss includes the value of the vehicle and any personal property inside. The integrity of the vehicle's access control system is permanently compromised until the BCM is re-secured. Fleet-wide, this vulnerability represents a significant risk if the TCU kernel is not patched.

Attack Tree [AND]: Unlock vehicle doors via BCM command injection

- [AND] Gain root access on TCU via CVE-2016-5195 → High

Cybersecurity Requirements

- CSR-001: Patch Linux kernel to version 4.8.4 or higher to remediate CVE-2016-5195.
- CSR-002: Implement CAN message authentication (SecOC) for BCM control frames.

Recommended Mitigations

- Apply OTA firmware update to TCU to patch CVE-2016-5195.
- Deploy CAN IDS to detect unauthorized diagnostic or control frames.

Inferences Made

- (Inferred) TCU uses standard Linux kernel SMS processing daemons.

Required Attack Equipment

- EQ Ettus USRP B210 for cellular base station emulation
- EQ Vector CANalyzer 17.0 for CAN frame injection
- EQ Bus Pirate v4 for hardware debugging

FS-003 Gateway Diagnostic Session Privilege Escalation via CVE-2014-3153 Enabling BCM Command Injection

Integrity | Feasibility: Low (16) | Risk Level: Medium | Confidence: high

Function Category: Access Control **Source Paths:** P9

Source Threats: Threat_24, Threat_62, Threat_109, Threat_153

Hardware: Gateway ARM Cortex-A7 | **Software:** Linux Kernel 3.10 | **Interfaces:** CAN + Ethernet

Safety	Financial	Operational	Privacy
Major	Major	Major	Moderate

Functional Impact

The Gateway's security controls are bypassed, allowing unauthorized access to the vehicle's internal CAN bus. This compromises the integrity of all control signals sent to the BCM. The vehicle's door lock system becomes fully controllable by the attacker. This failure state is critical as it allows for unauthorized vehicle entry.

Attack Narrative

The attacker compromises the TCU and uses it as a pivot to reach the Gateway. On the Gateway, the attacker exploits CVE-2014-3153 to gain root privileges. With root access, the attacker disables the Gateway's firewall rules that restrict CAN traffic. The attacker then sends unauthorized UDS diagnostic frames to the BCM to unlock the doors. This attack is highly effective because it leverages a known kernel vulnerability to bypass network-level security.

Damage Scenario

The vehicle's physical security is compromised, leading to potential theft. The financial impact is significant due to the loss of the vehicle. The integrity of the Gateway's security policy is invalidated. Fleet-wide, this requires a comprehensive firmware update for all affected Gateway units.

Attack Tree [AND]: Unlock doors via Gateway privilege escalation

- [AND] Escalate privileges on Gateway via CVE-2014-3153 → Low

Cybersecurity Requirements

- CSR-001: Patch Linux kernel to version 3.14.5 or higher to remediate CVE-2014-3153.
- CSR-002: Implement strict firewall rules on the Gateway to prevent unauthorized CAN frame injection.

Recommended Mitigations

- Update Gateway firmware to patch CVE-2014-3153.
- Implement hardware-based security (HSM) on the Gateway to enforce message authentication.

Inferences Made

- (Inferred) Gateway runs a Linux-based OS susceptible to kernel exploits.

Required Attack Equipment

- EQ JTAGulator for identifying debug ports
- EQ Vector CANalyzer 17.0 for CAN traffic analysis
- EQ Segger J-Link for firmware debugging

FS-004 Gateway XFRM Privilege Escalation via CVE-2017-16939 Enabling BCM Command Injection

Integrity | Feasibility: Low (16) | Risk Level: Medium | Confidence: high

Function Category: Access Control **Source Paths:** P13

Source Threats: Threat_24, Threat_63, Threat_109, Threat_153

Hardware: Gateway ARM Cortex-A7 | **Software:** Linux Kernel 4.10 | **Interfaces:** CAN + Ethernet

Safety	Financial	Operational	Privacy
Major	Major	Major	Moderate

Functional Impact

The Gateway's security is compromised, allowing unauthorized CAN bus access. This leads to the loss of integrity for BCM control signals. The door lock function is directly manipulated by the attacker. This is a critical security failure.

Attack Narrative

The attacker pivots from the TCU to the Gateway. On the Gateway, the attacker exploits CVE-2017-16939 to gain root privileges. The attacker then uses these privileges to bypass security restrictions and inject CAN frames to the BCM. The BCM processes these frames as legitimate commands, unlocking the doors. This attack demonstrates the danger of kernel-level vulnerabilities in shared Gateway hardware.

Damage Scenario

Unauthorized vehicle access is achieved, leading to potential theft. The financial impact is high. The integrity of the Gateway's security policy is compromised. Fleet-wide, this requires a firmware update for all Gateways.

Attack Tree [AND]: Unlock doors via Gateway XFRM exploit

- [AND] Escalate privileges on Gateway via CVE-2017-16939 → Low

Cybersecurity Requirements

- CSR-001: Patch Linux kernel to version 4.13.11 or higher to remediate CVE-2017-16939.
- CSR-002: Implement secure boot on the Gateway to prevent unauthorized code execution.

Recommended Mitigations

- Update Gateway firmware to patch CVE-2017-16939.
- Implement network segmentation on the Gateway.

Inferences Made

- (Inferred) Gateway uses XFRM for network security, making it vulnerable to CVE-2017-16939.

Required Attack Equipment

- EQ Vector CANalyzer 17.0 for CAN traffic analysis
- EQ Segger J-Link for firmware debugging
- EQ Saleae Logic Pro 16 for signal monitoring

FS-005 Gateway Network Bridging Misconfiguration Enabling BCM Command Injection

Integrity | Feasibility: High (7) | Risk Level: High | Confidence: high

Function Category: Communication **Source Paths:** P21

Source Threats: Threat_24, Threat_108, Threat_109, Threat_153

Hardware: Gateway ARM Cortex-A7 | **Software:** Linux Kernel 4.10 | **Interfaces:** CAN + Ethernet

Safety	Financial	Operational	Privacy
Major	Major	Major	Moderate

Functional Impact

The Gateway's network bridging functionality is abused to allow unauthorized CAN traffic to reach the BCM. This compromises the integrity of the BCM's control signals. The door lock function is directly manipulated by the attacker.

Attack Narrative

The attacker compromises the TCU and uses it to access the Gateway. The attacker then configures the Gateway to bridge the telematics network with the vehicle's internal CAN bus. This allows the attacker to send unauthorized CAN frames directly to the BCM. The BCM processes these frames as legitimate commands, unlocking the doors. This attack is simple to execute if the Gateway is misconfigured.

Damage Scenario

Unauthorized vehicle access is achieved. The financial impact is high. The integrity of the Gateway's network configuration is compromised. Fleet-wide, this requires a configuration update for all Gateways.

Attack Tree [OR]: Unlock doors via network bridging

- [OR] Abuse network bridging on Gateway → High

Cybersecurity Requirements

- CSR-001: Restrict network bridging on the Gateway to only authorized traffic.
- CSR-002: Implement a firewall on the Gateway to block unauthorized inter-network communication.

Recommended Mitigations

- Disable unnecessary network bridging on the Gateway.
- Implement strict firewall rules on the Gateway.

Inferences Made

- (Inferred) Gateway network bridging is not properly restricted.

Required Attack Equipment

- EQ BladeRF 2.0 for cellular signal manipulation
- EQ Vector CANalyzer 17.0 for CAN bus analysis
- EQ Busmaster 3.2.2 for protocol-level message injection

FS-006 Gateway Exposed Remote Service Exploitation Enabling BCM Command Injection

Integrity | Feasibility: High (7) | Risk Level: High | Confidence: high

Function Category: Communication **Source Paths:** P25

Source Threats: Threat_24, Threat_115, Threat_109, Threat_153

Hardware: Gateway ARM Cortex-A7 | **Software:** Custom remote service daemon | **Interfaces:** CAN + Ethernet

Safety	Financial	Operational	Privacy
Major	Major	Major	Moderate

Functional Impact

The Gateway's remote service is exploited to allow unauthorized CAN traffic to reach the BCM. This compromises the integrity of the BCM's control signals. The door lock function is directly manipulated by the attacker.

Attack Narrative

The attacker compromises the TCU and uses it to access the Gateway. The attacker then exploits a remote service running on the Gateway to gain unauthorized access to the vehicle's internal CAN bus. This allows the attacker to send unauthorized CAN frames directly to the BCM. The BCM processes these frames as legitimate commands, unlocking the doors. This attack is simple to execute if the remote service is vulnerable.

Damage Scenario

Unauthorized vehicle access is achieved. The financial impact is high. The integrity of the Gateway's remote services is compromised. Fleet-wide, this requires a firmware update for all Gateways.

Attack Tree [OR]: Unlock doors via remote service exploitation

- [OR] Exploit remote service on Gateway → High

Cybersecurity Requirements

- CSR-001: Disable all unnecessary remote services on the Gateway.
- CSR-002: Implement strong authentication for any required remote services on the Gateway.

Recommended Mitigations

- Disable unnecessary remote services on the Gateway.
- Implement strong authentication for remote services.

Inferences Made

- (Inferred) Gateway remote services are not properly secured.

Required Attack Equipment

- EQ Ettus USRP B210 for cellular signal manipulation
- EQ Vector CANalyzer 17.0 for CAN bus analysis
- EQ Busmaster 3.2.2 for protocol-level message injection

FS-007 Gateway Remote Service Exploitation Enabling BCM Command Injection

Integrity | Feasibility: High (7) | Risk Level: High | Confidence: high

Function Category: Communication **Source Paths:** P29

Source Threats: Threat_24, Threat_116, Threat_109, Threat_153

Hardware: Gateway ARM Cortex-A7 | **Software:** Custom remote service daemon | **Interfaces:** CAN + Ethernet

Safety	Financial	Operational	Privacy
Major	Major	Major	Moderate

Functional Impact

The Gateway's remote service is exploited to allow unauthorized CAN traffic to reach the BCM. This compromises the integrity of the BCM's control signals. The door lock function is directly manipulated by the attacker.

Attack Narrative

The attacker compromises the TCU and uses it to access the Gateway. The attacker then exploits a remote service running on the Gateway to gain unauthorized access to the vehicle's internal CAN bus. This allows the attacker to send unauthorized CAN frames directly to the BCM. The BCM processes these frames as legitimate commands, unlocking the doors. This attack is simple to execute if the remote service is vulnerable.

Damage Scenario

Unauthorized vehicle access is achieved. The financial impact is high. The integrity of the Gateway's remote services is compromised. Fleet-wide, this requires a firmware update for all Gateways.

Attack Tree [OR]: Unlock doors via remote service exploitation

- [OR] Exploit remote service on Gateway → High

Cybersecurity Requirements

- CSR-001: Disable all unnecessary remote services on the Gateway.
- CSR-002: Implement strong authentication for any required remote services on the Gateway.

Recommended Mitigations

- Disable unnecessary remote services on the Gateway.
- Implement strong authentication for remote services.

Inferences Made

- (Inferred) Gateway remote services are not properly secured.

Required Attack Equipment

- EQ BladeRF 2.0 for cellular signal manipulation
- EQ Vector CANalyzer 17.0 for CAN bus analysis
- EQ Busmaster 3.2.2 for protocol-level message injection

FS-008 Gateway Network Sniffing Enabling BCM Command Injection

Confidentiality | Feasibility: High (7) | Risk Level: High | Confidence: high

Function Category: Communication **Source Paths:** P5

Source Threats: Threat_24, Threat_88, Threat_109, Threat_153

Hardware: Gateway ARM Cortex-A7 | **Software:** Linux Kernel 4.10 | **Interfaces:** CAN + Ethernet

Safety	Financial	Operational	Privacy
Major	Major	Major	Moderate

Functional Impact

The Gateway's network traffic is sniffed to discover internal network traffic. This compromises the confidentiality of the vehicle's internal communications. The door lock function is directly manipulated by the attacker.

Attack Narrative

The attacker compromises the TCU and uses it to access the Gateway. The attacker then performs network sniffing on the Gateway to discover internal network traffic. This allows the attacker to identify the CAN frames used to unlock the doors. The attacker then sends these frames to the BCM, unlocking the doors. This attack is simple to execute if the network traffic is not encrypted.

Damage Scenario

Unauthorized vehicle access is achieved. The financial impact is high. The confidentiality of the vehicle's internal communications is compromised. Fleet-wide, this requires a firmware update for all Gateways.

Attack Tree [OR]: Unlock doors via network sniffing

- [OR] Sniff network traffic on Gateway → High

Cybersecurity Requirements

- CSR-001: Implement network segmentation on the Gateway to prevent unauthorized sniffing.
- CSR-002: Use encrypted communication protocols for all internal network traffic.

Recommended Mitigations

- Implement network segmentation on the Gateway.
- Use encrypted communication protocols.

Inferences Made

- (Inferred) Gateway network traffic is not encrypted.

Required Attack Equipment

- EQ HackRF One for cellular signal manipulation
- EQ Vector CANalyzer 17.0 for CAN bus analysis
- EQ Busmaster 3.2.2 for protocol-level message injection

FS-009 Gateway Credential Sniffing Enabling BCM Command Injection

Confidentiality | Feasibility: High (7) | Risk Level: High | Confidence: high

Function Category: Communication **Source Paths:** P17

Source Threats: Threat_24, Threat_88, Threat_109, Threat_153

Hardware: Gateway ARM Cortex-A7 | **Software:** Linux Kernel 4.10 | **Interfaces:** CAN + Ethernet

Safety	Financial	Operational	Privacy
Major	Major	Major	Moderate

Functional Impact

The Gateway's network traffic is sniffed to gain credentials. This compromises the confidentiality of the vehicle's internal communications. The door lock function is directly manipulated by the attacker.

Attack Narrative

The attacker compromises the TCU and uses it to access the Gateway. The attacker then performs network sniffing on the Gateway to gain credentials. This allows the attacker to identify the CAN frames used to unlock the doors. The attacker then sends these frames to the BCM, unlocking the doors. This attack is simple to execute if the network traffic is not encrypted.

Damage Scenario

Unauthorized vehicle access is achieved. The financial impact is high. The confidentiality of the vehicle's internal communications is compromised. Fleet-wide, this requires a firmware update for all Gateways.

Attack Tree [OR]: Unlock doors via credential sniffing

- [OR] Sniff credentials on Gateway → High

Cybersecurity Requirements

- CSR-001: Implement network segmentation on the Gateway to prevent unauthorized sniffing.
- CSR-002: Use encrypted communication protocols for all internal network traffic.

Recommended Mitigations

- Implement network segmentation on the Gateway.
- Use encrypted communication protocols.

Inferences Made

- (Inferred) Gateway network traffic is not encrypted.

Required Attack Equipment

- EQ HackRF One for cellular signal manipulation
- EQ Vector CANalyzer 17.0 for CAN bus analysis
- EQ Busmaster 3.2.2 for protocol-level message injection

FS-010 Gateway Network Sniffing Enabling BCM Immobilizer Bypass

Confidentiality | Feasibility: High (7) | Risk Level: Critical | Confidence: high

Function Category: Communication **Source Paths:** P37

Source Threats: Threat_24, Threat_88, Threat_109, Threat_165

Hardware: Gateway ARM Cortex-A7 | **Software:** Linux Kernel 4.10 | **Interfaces:** CAN + Ethernet

Safety	Financial	Operational	Privacy
Severe	Severe	Severe	Major

Functional Impact

The Gateway's network traffic is sniffed to discover internal network traffic. This compromises the confidentiality of the vehicle's internal communications. The immobilizer system is directly manipulated by the attacker.

Attack Narrative

The attacker compromises the TCU and uses it to access the Gateway. The attacker then performs network sniffing on the Gateway to discover internal network traffic. This allows the attacker to identify the CAN frames used to deactivate the immobilizer. The attacker then sends these frames to the BCM, deactivating the immobilizer. This attack is simple to execute if the network traffic is not encrypted.

Damage Scenario

Unauthorized vehicle access is achieved. The financial impact is high. The confidentiality of the vehicle's internal communications is compromised. Fleet-wide, this requires a firmware update for all Gateways.

Attack Tree [OR]: Bypass immobilizer via network sniffing

- [OR] Sniff network traffic on Gateway → High

Cybersecurity Requirements

- CSR-001: Implement network segmentation on the Gateway to prevent unauthorized sniffing.
- CSR-002: Use encrypted communication protocols for all internal network traffic.

Recommended Mitigations

- Implement network segmentation on the Gateway.
- Use encrypted communication protocols.

Inferences Made

- (Inferred) Gateway network traffic is not encrypted.

Required Attack Equipment

- EQ HackRF One for cellular signal manipulation
- EQ Vector CANalyzer 17.0 for CAN bus analysis
- EQ Busmaster 3.2.2 for protocol-level message injection

Cross-Scenario Insights

Systemic vulnerabilities include the lack of inter-ECU authentication on the CAN bus and the exposure of diagnostic services on the Gateway. Linux kernel vulnerabilities (CVE-2016-5195, CVE-2014-3153, CVE-2017-16939) are consistently exploited to gain root privileges on the TCU and Gateway. The Gateway is the most frequently targeted ECU due to its role as a bridge between the telematics and control domains.

Priority Mitigation Plan

Immediate actions include patching the TCU and Gateway kernels to remediate known CVEs. Medium-term mitigations involve implementing SecOC for CAN message authentication and network segmentation on the Gateway. Long-term requirements include deploying a CAN IDS and conducting regular penetration testing.

Lifecycle Considerations

CVEs require urgent OTA patching due to active exploitation risk. The lack of inter-ECU authentication requires architectural redesign for future vehicle platforms.

7. Attack Feasibility Rating

Mode: remote | Derived CAL: CAL4 | Impact Basis: Major

Threat ID	Threat Name	Feasibility	Risk Level	CAL	Risk Treatment Decision
Threat_98	Network Service Scanning	High	High	CAL4	Reduce and define cybersecurity goals
Threat_109	Exploit ECU for Lateral Movement	High	High	CAL4	Reduce and define cybersecurity goals
Threat_116	Remote services in In-Vehicle Network	High	High	CAL4	Reduce and define cybersecurity goals
Threat_40	External Remote Services	High	High	CAL4	Reduce and define cybersecurity goals
Threat_115	Exploitation of Remote Services in In-Vehicle Network	High	High	CAL4	Reduce and define cybersecurity goals
Threat_63	Exploit Co-Located Computing Device for Privilege Escalation	High	High	CAL4	Reduce and define cybersecurity goals
Threat_24	Malicious SMS	High	High	CAL4	Reduce and define cybersecurity goals
Threat_62	Abuse Elevation Control Mechanism	Low	Medium	CAL4	Reduce if feasible, otherwise retain with explicit rationale
Threat_88	Network Sniffing	High	High	CAL4	Reduce and define cybersecurity goals
Threat_108	Bridge Vehicle Networks	High	High	CAL4	Reduce and define cybersecurity goals
Threat_153	Control Doors	High	High	CAL4	Reduce and define cybersecurity goals
Threat_165	Vehicle Theft	High	High	CAL4	Reduce and define cybersecurity goals

8. Risk Value Determination

Internal Rule: Risk level is derived from *maximum impact* and *attack feasibility*. The score is calculated as Impact(0-4) + Feasibility(0-4), then mapped to Low, Medium, High, or Critical.

- 0-2: Low
- 3-4: Medium
- 5-6: High
- 7-8: Critical

9. Risk Treatment Decision

For each identified threat scenario, the recommended treatment is shown in the table above. High or Critical risks should be reduced and traced to cybersecurity goals. Medium risks may be reduced or retained with an explicit rationale. Low risks may be retained with documented assumptions and monitoring.